

User–Server Interaction: Cookies

Understanding how HTTP maintains user identity and sessions

Introduction

HTTP is a **stateless protocol**, meaning each request is independent of previous ones. This simplifies server design and enables high performance, but creates a challenge: *How can a server remember users across multiple requests?*

The solution is **Cookies** (defined in RFC 6265), which allow servers to identify users and create a session layer on top of HTTP.

Key Idea

Cookies provide a mechanism for maintaining state between a client and server, enabling personalized services, shopping carts, and user sessions.

Cookie Technology Components

Cookie technology relies on four main components:

1. A **Set-Cookie** header line in the HTTP **response message**.
2. A **Cookie** header line in the HTTP **request message**.
3. A **cookie file** stored on the client's browser.
4. A **back-end database** maintained by the web server.

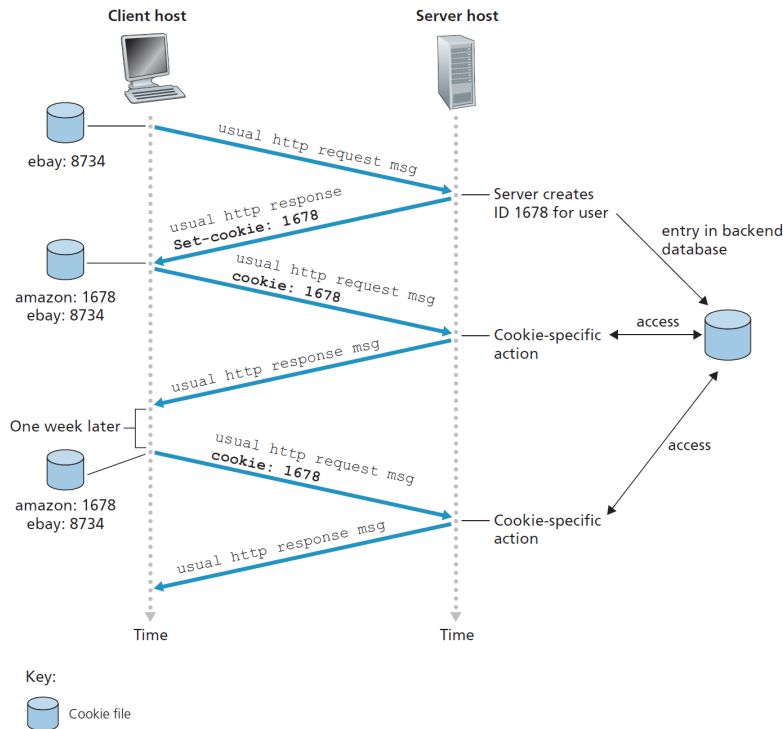


Figure 1: Cookie mechanism flow between client, browser, and server (placeholder image).

How Cookies Work: An Example

Suppose Susan visits Amazon.com for the first time.

Step 1: Server Creates Cookie

- The Amazon server generates a unique ID (e.g., 1678).
- It stores this ID in its back-end database.
- The server responds with a header:

Example Header

Set-Cookie: 1678

Step 2: Browser Stores Cookie

- Susan's browser receives the **Set-Cookie** header.
- It appends an entry (Amazon.com : 1678) to its **cookie file**.
- The cookie file may already contain entries from other sites (e.g., eBay).

Step 3: Client Sends Cookie with Requests

- On subsequent requests to Amazon, the browser adds:

Example Request Header

Cookie: 1678

- The server identifies the user as “1678” and retrieves session data.

Step 4: Persistent User Identity

- If Susan revisits Amazon later, the browser still sends `Cookie: 1678`.
- Amazon can personalize recommendations and maintain a shopping cart.
- If Susan registers (name, address, payment info), Amazon associates her ID with real identity.

Applications of Cookies

Cookies can be used for multiple purposes:

- **Authorization:** Verifying a user is logged in and authorized.
- **Shopping Carts:** Maintaining product lists during e-commerce sessions.
- **Recommendations:** Suggesting items based on browsing history.
- **User Session State:** Enabling continuity in services like web-based e-mail.

Challenge: Maintaining State

Cookies solve the problem of keeping state across multiple HTTP transactions.

- At protocol endpoints: maintain state at sender/receiver over multiple transactions.
- In messages: cookies in HTTP request/response headers carry state.

Cookies and Privacy

While cookies simplify user experience, they also raise privacy challenges.

Tracking Behavior

- Sites can track user activity on their own site (**first-party cookies**).
- Third-party cookies (e.g., from ad networks) track user behavior across multiple sites.
- Example:
 - User loads a page from `nytimes.com`.
 - Browser also fetches an ad from `AdX.com`.
 - `AdX.com` sets a cookie, enabling tracking across sites with AdX ads.

First-Party vs Third-Party Cookies

- **First-party cookies:** From the website you intentionally visit (e.g., NYTimes base page).
- **Third-party cookies:** From domains you did not visit directly (e.g., ads, trackers).

User Tracking

- First-party cookies: Track activity within one site.
- Third-party cookies: Track activity across multiple sites, often invisibly (e.g., hidden links).
- Enables targeted ads based on browsing history.

Modern Browser Policies

- Disabled by default in Firefox and Safari.
- To be disabled in Google Chrome by 2023.

Legal and Regulatory Aspects

- Under the **EU GDPR**, cookies that can identify an individual are considered personal data.
- Users must have explicit control over whether cookies are allowed.

Important Note

Cookies provide powerful personalization features but must be carefully managed to balance convenience with privacy and legal compliance.

Summary

- HTTP is stateless; cookies enable state management.
- They support sessions, personalization, and shopping carts.
- Privacy concerns arise with third-party tracking cookies.
- Regulations like **GDPR** give users control over cookie usage.